

Marco integrativo GQM + PRAGMATIC para indicadores SOAR nacionales

1. Introducción

Este documento integra la metodología **GQM (Goal-Question-Metric)** con los criterios **PRAGMATIC** para el diseño y evaluación de indicadores SOAR (Security Orchestration, Automation and Response) aplicables a un marco nacional, tomando como referencia el contexto español y las tendencias internacionales recientes en métricas de ciberseguridad, incidentes y automatización.[web:12][web:13][web:24]

El objetivo es asegurar la trazabilidad desde los objetivos nacionales de ciberseguridad (reducción de tiempo e impacto de los incidentes, cumplimiento regulatorio, mejora de la resiliencia) hasta las métricas técnicas de SOC y SOAR, evaluando a la vez la calidad de cada métrica bajo los nueve criterios PRAGMATIC: **Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente y Rentable**. [web:22][web:26]

2. Resumen de objetivos nacionales (nivel G de GQM)

A efectos de este marco, se consideran cuatro grandes objetivos nacionales (G1-G4), derivados de estrategias de ciberseguridad, NIS2, ENS y guías de ENISA/NIST:[web:39][web:22][web:24]

- G1. Reducir el tiempo de detección, análisis, contención y recuperación de incidentes a nivel nacional, especialmente en sectores esenciales y servicios digitales críticos.
- G2. Aumentar la cobertura y calidad de la automatización en procesos de detección y respuesta, de forma compatible con la seguridad operativa y regulatoria.
- G3. Mejorar el cumplimiento de obligaciones regulatorias y la calidad del reporting (NIS2, ENS, RGPD, regulaciones sectoriales) mediante procesos soportados por SOAR.
- G4. Optimizar el impacto económico de la ciberseguridad, maximizando el valor (reducción de impacto y riesgo) por euro invertido en capacidades SOAR y SOC.

Estos objetivos se concretan en preguntas (Q) que, a su vez, se operacionalizan en métricas (M) cuantitativas y cualitativas.[web:22]

3. GQM para indicadores de tiempo (MTTD, MTTC, MTTR, dwell time)

3.1. Objetivo G1 - Tiempo de respuesta nacional

G1: Reducir de forma sostenida los tiempos de detección, análisis, contención y recuperación de incidentes significativos, mejorando la resiliencia nacional frente a amenazas (incluido ransomware y ataques a OT).[web:13][web:10][web:12]

Preguntas (Q)

- Q1.1: ¿Con qué rapidez se detectan, analizan y contienen los incidentes críticos en las organizaciones nacionales y por sector NIS2?
- Q1.2: ¿En qué medida contribuye la automatización (SOAR) a reducir esos tiempos frente a una línea base previa?
- Q1.3: ¿Cuál es el tiempo de permanencia medio del atacante (dwell time) en sectores críticos y cómo evoluciona?

Métricas (M)

- M1.1 – MTDD nacional y sectorial (Mean Time to Detect): tiempo medio desde la ocurrencia o primera evidencia del incidente hasta su detección formal.[web:24][web:22]
- M1.2 – MTTC/MTTI nacional (Mean Time to Triage/Contain): tiempo medio desde la detección hasta la clasificación y contención inicial.[web:24]
- M1.3 – MTTR nacional (Mean Time to Respond/Restore): tiempo medio desde la detección hasta la recuperación de servicios a un estado aceptable.[web:24]
- M1.4 – Dwell time estimado en sectores críticos: tiempo medio entre el compromiso inicial y la expulsión del atacante, tomando referencias de incidentes OT y ransomware.[web:13][web:10]
- M1.5 – % de reducción de MTDD/MTTR atribuida a proyectos SOAR: comparación de tiempos pre- y post-automatización, por sector y tipo de incidente.[web:16][web:26]

4. GQM para cobertura y calidad de automatización

4.1. Objetivo G2 – Cobertura de automatización

G2: Aumentar la proporción de procesos de detección y respuesta soportados por automatización y orquestación, manteniendo o mejorando la calidad y seguridad operativa.[web:16][web:22]

Preguntas (Q)

- Q2.1: ¿Qué porcentaje del volumen de alertas e incidentes se procesa mediante flujos automatizados o semiautomatizados?
- Q2.2: ¿Qué proporción de los casos de uso más frecuentes cuenta con playbooks definidos y operativos?
- Q2.3: ¿En qué medida los playbooks se ejecutan de forma exitosa, sin intervenciones manuales imprevistas ni rollbacks de emergencia?

Métricas (M)

- M2.1 – % de alertas tratadas mediante flujos automatizados: proporción del total de alertas del SOC gestionadas por SOAR, total y por tipo de alerta.[web:16]
- M2.2 – % de incidentes gestionados con soporte de SOAR: proporción de incidentes categorizados donde interviene algún playbook.[web:22]
- M2.3 – Cobertura de casos de uso: porcentaje de los 10 tipos de incidentes más frecuentes que tienen al menos un playbook definido.[web:5]
- M2.4 – Tasa de éxito de playbooks: porcentaje de ejecuciones completadas según lo diseñado, sin errores ni interrupciones.[web:16]
- M2.5 – Tasa de excepciones y rollbacks: porcentaje de ejecuciones que requieren intervención manual no planificada o reversión de acciones.[web:22]

5. GQM para cumplimiento y reporting

5.1. Objetivo G3 – Cumplimiento regulatorio soportado por SOAR

G3: Mejorar la capacidad de las organizaciones para cumplir plazos y requisitos de notificación de incidentes y reporting, utilizando automatización donde sea razonable.[web:39][web:36]

Preguntas (Q)

- Q3.1: ¿Qué proporción de organizaciones utiliza SOAR para preparar o automatizar notificaciones a CNCS, INCIBE y reguladores sectoriales?
- Q3.2: ¿Con qué rapidez se realizan las notificaciones iniciales requeridas por NIS2 y normativa sectorial?
- Q3.3: ¿En qué medida los informes de incidente contienen la información mínima requerida, de forma estructurada y reutilizable?

Métricas (M)

- M3.1 – % de organizaciones que usan SOAR para notificación/regulación: indicador de adopción funcional.[web:39]
- M3.2 – Tiempo medio hasta notificación inicial: desde detección hasta envío de notificación a la autoridad competente.[web:39][web:42]
- M3.3 – % de notificaciones dentro del plazo regulatorio (p. ej. 24 h NIS2): cumplimiento temporal.[web:39]
- M3.4 – Grado de estructuración de informes de incidente: presencia de plantillas normalizadas y campos obligatorios.[web:22]

6. GQM para impacto económico y ROI

6.1. Objetivo G4 – Impacto y coste

G4: Optimizar la relación entre coste de incidentes, inversión en SOAR y beneficio (reducción de impacto), mejorando la eficiencia global del ecosistema de ciberseguridad.[web:26][web:28]

Preguntas (Q)

- Q4.1: ¿En qué medida se estiman y registran los costes de los incidentes a nivel organizativo y sectorial?
- Q4.2: ¿Cómo evolucionan estos costes en función de la madurez SOAR (cobertura, tiempos, calidad)?
- Q4.3: ¿Qué retorno se observa en proyectos de automatización concretos, comparando inversión y ahorro?

Métricas (M)

- M4.1 – % de organizaciones que estiman coste de incidentes: existencia de cultura de medición económica.[web:26]
- M4.2 – Coste medio anual de incidentes por organización / sector: en euros, agregados y segmentados.[web:26]
- M4.3 – Inversión anual en capacidades SOAR: licencias, servicios, operación.[web:26]
- M4.4 – ROI de proyectos SOAR: (Ahorro en costes de incidentes) / (Inversión en SOAR).[web:26]
- M4.5 – Correlación entre IGM SOAR y reducción de coste/incidentes: análisis estadístico de relación entre madurez y resultados.[web:28]

7. Calificación PRAGMATIC de las métricas (visión general)

Cada métrica anterior se evalúa con los criterios PRAGMATIC, mediante escala cualitativa Alta (A), Media (M), Baja (B). La matriz completa se desarrolla en el documento específico, pero a modo de síntesis:

- Métricas de tiempo (MTTD, MTTR, MTTC, dwell time) suelen ser Altamente predictivas, relevantes y accionables, aunque su precisión y oportunidad dependen de la calidad del registro de incidentes. [web:24][web:22]
- Métricas de cobertura y calidad de automatización (porcentaje de alertas automatizadas, tasa de éxito de playbooks) son altamente accionables y significativas para gestión de SOC, con buena rentabilidad si se integran en cuadros de mando.[web:16][web:19]
- Métricas de cumplimiento (tiempo a notificación, % dentro de plazo) son altamente relevantes y precisas, pero su poder predictivo del riesgo técnico es limitado; brillan más en la dimensión regulatoria.[web:39][web:36]
- Métricas económicas y de ROI son muy significativas y potencialmente independientes, pero su precisión y genuinidad dependen de supuestos y modelos; requieren mayor madurez analítica. [web:26][web:28]

La combinación GQM + PRAGMATIC permite priorizar qué métricas deben ocupar el centro del tablero nacional y cuáles conviene mantener como indicadores secundarios o experimentales.